

Desenvolvimento de Serviços com Spring Boot

Etapa/Aula 08.1

Professor(a): Flávio Neves

E-mail: flavio.neves@prof.infnet.edu.br

Autenticação, Autorização e Otimização de Segurança

Roteiro da Aula

- **Introdução de segurança em APIs**
- **Autenticação, Autorização e Otimização de Segurança**

Introdução de segurança em APIs

- Muitas aplicações manipulam dados sensíveis dos usuários, como informações pessoais, dados bancários, etc.
- Um vazamento dessas informações pode resultar em enormes prejuízos financeiros e de reputação.

Introdução de segurança em APIs

- A confiança é um fator fundamental para o sucesso de qualquer aplicação.
- Se os usuários não confiarem na segurança da sua aplicação, eles irão abandoná-la.

Introdução de segurança em APIs

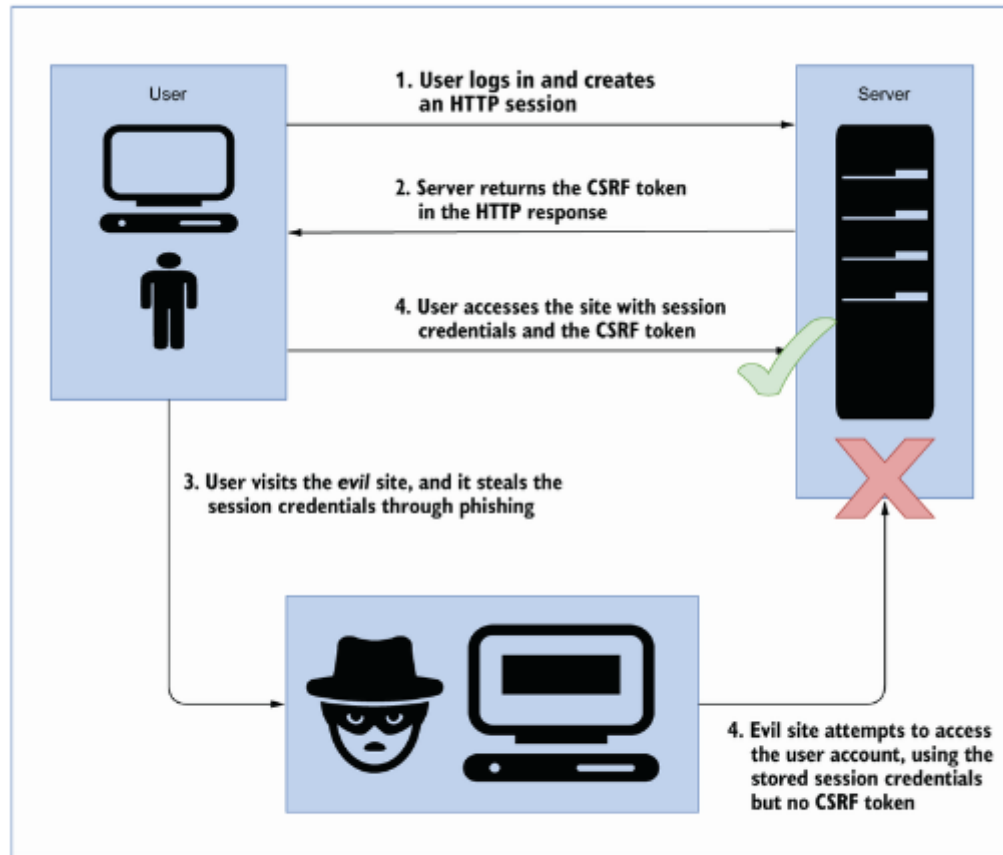
- Dependendo da região ou da natureza da aplicação, podem existir regulamentos específicos sobre proteção de dados (como a LGPD no Brasil e a GDPR na Europa).
- A falta de conformidade pode resultar em multas pesadas.

Introdução de segurança em APIs

- Ao desenvolver uma API, é essencial garantir a segurança dos dados e dos sistemas envolvidos.
- Com o contínuo avanço da tecnologia e a crescente adoção de aplicações web, a segurança das informações se tornou mais crítica do que nunca.
- Um dos frameworks mais populares para o desenvolvimento de aplicações Java é o Spring, e embora ofereça muitas facilidades para os desenvolvedores, a segurança é um aspecto que não pode ser negligenciado.

Introdução de segurança em APIs

- O Spring Security é um módulo poderoso do ecossistema Spring que oferece autenticação, autorização e outras características de segurança para aplicações Spring. Alguns dos principais recursos de segurança do SpringBoot são:
 - **Autenticação**
 - **Autorização**
 - **Proteção contra ataques comuns**
 - **Integração com OAuth2**



O que é Autenticação?

- Um ato, processo ou método de mostrar que algo (como uma identidade, uma obra de arte ou uma transação financeira) é real, verdadeiro ou genuíno; o ato ou processo de autenticar algo.
- Simplificando, a autenticação é provar que alguém (ou algo) é quem (ou o que, no caso de um dispositivo, aplicativo ou serviço) afirma ser.

O que é Autenticação?

- Basicamente podemos dizer que a autenticação é o login na nossa aplicação. Trata-se da etapa de verificação se um determinado usuário possui credenciais (geralmente, combinação de login e senha) válidas para acessar a nossa aplicação.
- Especificamente o sistema de autenticação do Spring Security pode ser configurado para que utilize diferentes estratégias de autenticação, pois o mesmo trabalha com o conceito de providers de autenticação.

O que é Autenticação?

- O Spring Security oferece uma maneira abrangente de gerenciar a autenticação, permitindo que os desenvolvedores configurem fontes de autenticação, como bancos de dados, LDAP (lightweight directory access protocol), etc.

O que é Autorização?

- **1: o ato de autorizar;**
- **2: um instrumento que autoriza: SANÇÃO**

O que é Autorização?

- Já a autorização é um processo que acontece depois da autenticação. É o momento onde a aplicação verifica se o usuário atualmente autenticado tem permissão de acesso a um determinado recurso.
- O sistema de autorização do Spring Security também é bastante flexível, pois nos permite definir com facilidade quais são os possíveis tipos de usuários da nossa aplicação, como o sistema relaciona cada usuário com o seu determinado tipo e quais rotas de nossa aplicação cada tipo de usuário terá acesso.

O que é Autorização?

- Toda essa flexibilidade do Spring Security é possível por que o mesmo nos disponibiliza algumas interfaces que devem ser implementadas e assim informamos qual será a regra de negócio de nossa aplicação para a realização dos processos de autenticação e autorização.

O que é Autorização?

- Uma vez autenticado, o Spring Security permite definir regras de acesso detalhadas sobre quem pode acessar quais recursos na sua aplicação.
- Spring Security fornece proteção contra muitos ataques comuns, como CSRF (Cross-Site Request Forgery), sessão fixa, etc.
- Para aplicações que necessitam de OAuth2, o Spring Security oferece integração robusta e flexível.

Armazenamento de Senha

- Além dos sistemas de autenticação, autorização e proteção contra diferentes tipos de vulnerabilidades de aplicações web.
- O Spring Security também disponibiliza algoritmos de criptografias que evitam que sua aplicação guarde as senhas de seus usuários em texto puro no banco de dados.
- Os algoritmos disponibilizados no Spring Security são o bcrypt, PBKDF2, scrypt e argon2. Sendo o bcrypt o mais utilizado pela comunidade.

Autenticação e autorização

- O Spring Security é um módulo do Spring Boot que oferece recursos para autenticação e autorização em aplicações.
- Ele permite a configuração de autenticação baseada em diferentes métodos, como login com nome de usuário e senha, autenticação baseada em tokens ou integração com provedores de autenticação externos, como OAuth.
- Além disso, o Spring Security permite a definição de regras de autorização para controlar o acesso a recursos protegidos.

Proteção contra ataques

- O Spring Boot inclui recursos para proteção contra ataques comuns, como ataques de injeção SQL, cross-site scripting (XSS) e cross-site request forgery (CSRF).
- Esses recursos são fornecidos por meio de bibliotecas como Spring Data JPA, Spring MVC e Spring Security, que implementam práticas de segurança recomendadas para evitar vulnerabilidades conhecidas.

Validação de entrada

- É importante validar todas as entradas de dados recebidas pela API para evitar ataques de injeção ou manipulação de dados.
- O Spring Boot fornece recursos de validação de entrada por meio de anotações, permitindo que os desenvolvedores definam regras de validação para os parâmetros da API.

Criptografia e segurança de dados

- O Spring Boot oferece suporte à criptografia de dados em trânsito e em repouso.
- É possível configurar o uso de protocolos seguros, como HTTPS, para proteger a comunicação entre a API e os clientes.
- Além disso, o Spring Security permite a configuração de políticas de criptografia para proteger dados sensíveis armazenados no banco de dados.

Monitoramento e logging

- A implementação de recursos de monitoramento e logging é essencial para detectar e responder a possíveis incidentes de segurança.
- O Spring Boot possui integração com ferramentas populares de monitoramento e logging, como o Spring Boot Actuator e o Logback, permitindo o registro e a análise de eventos de segurança.

Segurança com OAuth2

- OAuth2 é um protocolo de autorização que permite a aplicativos obter acesso limitado a contas de usuário em um servidor HTTP. Ele é especialmente útil para garantir a segurança em aplicações que acessam serviços de terceiros.
- Integrar OAuth2 com Spring Boot pode elevar significativamente a segurança dos seus aplicativos, permitindo um controle mais refinado sobre quem tem acesso ao quê.
- A implementação do OAuth2 com Spring Boot pode ser simplificada com o uso de Spring Security OAuth2, que oferece suporte para servidores de autorização e recursos, bem como para clientes OAuth2. Isso facilita a proteção de suas APIs REST e a gestão de permissões de acesso.

Spring Security

- Primeiramente o Spring Security é um framework do projeto Spring que possui um sistema de autenticação e autorização de alto nível e altamente customizável para aplicações Java.
- A framework inclusive é a solução oficial para implementação de recursos de segurança em aplicações Spring Boot, porém ele também pode ser utilizado em conjunto com outras frameworks.

Spring Security

- Ele simplifica a implementação de recursos de segurança comuns, como login de usuário, controle de acesso baseado em papéis e proteção contra ataques de segurança, como cross-site scripting (XSS) e cross-site request forgery (CSRF).

Funcionalidades do Spring Security

- Ainda que o foco do Spring Security seja o sistema de autenticação e autorização, ele possui outras funcionalidades que aumentam a segurança de nossas aplicações Java, aqui vai uma lista de algumas de suas principais funcionalidades:
 - Sistema de autenticação
 - Sistema de autorização
 - Proteção contra ataques como session fixation, clickjacking e cross site request forgery
 - Integração com a Servlet API
 - Integração opcional com o Spring Web MVC
 - Fácil instalação através de um starter Spring Boot

Segurança no Spring Boot

- Spring Security permite a definição de regras de autorização para controlar o acesso a recursos protegidos.

Segurança no Spring Boot

- **Proteção contra ataques:** O Spring Boot inclui recursos para proteção contra ataques comuns, como ataques de injeção SQL, cross-site scripting (XSS) e cross-site request forgery (CSRF).

Segurança no Spring Boot

- **Validação de entrada:** É importante validar todas as entradas de dados recebidas pela API para evitar ataques de injeção ou manipulação de dados.
- O Spring Boot fornece recursos de validação de entrada por meio de anotações, permitindo que os desenvolvedores definam regras de validação para os parâmetros da API.

Segurança no Spring Boot

- **Criptografia e segurança de dados:** O Spring Boot oferece suporte à criptografia de dados em trânsito e em repouso.
- É possível configurar o uso de protocolos seguros, como HTTPS, para proteger a comunicação entre a API e os clientes.
- Além disso, o Spring Security permite a configuração de políticas de criptografia para proteger dados sensíveis armazenados no banco de dados.

Conclusão

- A segurança é um aspecto crítico ao lidar com APIs, e é aqui que o Spring Boot se destaca. Ele oferece recursos e práticas recomendadas para garantir a segurança das aplicações.
- Através do Spring Security, é possível configurar mecanismos de autenticação e autorização robustos, garantindo que apenas usuários autorizados tenham acesso aos recursos protegidos.
- Ao adotar as boas práticas de segurança do Spring Boot e aproveitar seus recursos embutidos, os desenvolvedores podem construir APIs seguras e confiáveis, estabelecendo confiança e preservando a integridade dos sistemas envolvidos.
- A segurança das APIs é essencial para proteger dados sensíveis, garantir a privacidade dos usuários e manter a confiabilidade das aplicações.

Conclusão

- Manter a segurança em aplicações Spring é vital para proteger dados sensíveis, manter a confiança dos usuários e cumprir com regulamentos legais.
- O Spring Security é uma ferramenta poderosa que ajuda os desenvolvedores a implementar medidas de segurança robustas de forma eficaz e eficiente.
- Ao integrar o Spring Security na sua aplicação Spring, você dá um grande passo para garantir que sua aplicação seja segura e confiável.



Desenvolvimento de Serviços com Spring Boot

Etapa/Aula 08.1

Professor(a): Flávio Neves

E-mail: flavio.neves@prof.infnet.edu.br